



File No.: EXP202306832

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 11, 2023, six complaints were filed with the Spanish Agency for Data Protection regarding a possible infringement attributable to MAD COOL FESTIVAL, S.L. with NIF B87381042 (hereinafter, MAD COOL).

The facts brought to the attention of this authority are as follows:

The complainants state that they were affected by the personal data breach that occurred on the website <https://www.madcoolarea.es/area/> on April 11, 2023.

On that day, MAD COOL opened said webpage to confirm the shipping details of wristbands for the music festival it was organizing. Once users entered their access data (email account and entry code), they could view the personal data of other individuals who were also registered on the platform.

Along with the submissions, the following is provided:

- Screenshots of the platform of the respondent at the time of the incident, showing third-party data (name, surname, email, phone number, postal address, postal code, city, and country).
- An email sent by the respondent on April 11, 2023, urging access to its webpage to confirm the postal address for the shipment of wristbands.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), this complaint was forwarded to MAD COOL for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

MAD COOL responded to the request by written communication dated June 23 and 30, 2023.

THIRD: On July 10, 2023, in accordance with Article 65 of the LOPDGDD, the complaint was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

As a result of the actions taken, the following aspects have been noted:

1.- Notification of the breach.

MAD COOL confirms in its response to the transfer that it did not notify this Agency of the breach. As stated: "The security breach has not been reported to the Spanish Agency for Data Protection as it did not pose a risk or high risk to the rights and fundamental freedoms of individuals. This conclusion is reached after qualitatively and quantitatively analyzing the incident that occurred and considering various parameters such as the volume of affected data, category or type of affected data, and the scale of exposure of the same."

2.- Analysis of the breach.

2.1. Chronology of events.

The chronology of the events of the incident according to the General Subdirectorate for Data Inspection is as follows:

On April 11, 2023, MAD COOL launched a confirmation form for the personal data of users who purchased tickets for the festival taking place in July of that year. At the time of this launch, the security

incident occurred that caused the breach.

The origin of the problem was due to the fact that during the morning of the launch of the web form, a migration of the platform to a new server was carried out, and during that migration, an existing micro-cache on that server was not deactivated. MAD COOL states regarding this server configuration error: "it is, therefore, a human error, isolated and completely unintentional."

This 2-second micro-cache caused that from the moment a user accessed the form, for a maximum of 2 seconds, subsequent users accessing it could see their data. Once those 2 seconds elapsed, the user's data would no longer be displayed. According to the statements provided: "When a user logged in to the form, the next users accessing during the following two seconds could see another person's data instead of their own. Users only saw their own data when no one had logged in before those two seconds."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/23

Initially, MAD COOL stated that it detected the failure at 15:15 on April 11 and proceeded to close the relevant form to minimize the impact of the breach. As MAD COOL initially indicated, by 15:45 the problem was considered resolved. Subsequently, it was clarified that the time window of the incident would be from 14:45 to 15:15. This latter version is consistent with the supporting documentation provided regarding the number of affected users, as well as the report from the data processor. On April 12, 2023, MAD COOL stated that it began receiving emails from users affected by the incident, informing about it and requesting explanations regarding what had happened. Subsequently, on April 13, 2023, MAD COOL issued a public statement on its website, as will be detailed later.

2.2. Actions taken to minimize adverse effects and measures adopted for final resolution.

As indicated, once the incident was acknowledged, access to the form was closed to prevent a greater number of users from being involved in the breach. MAD COOL states the following in this regard: "At the moment the security incident occurred during the migration from one server to another, immediate closure of access to the form was carried out, a complete review of all its security was conducted, and the micro-caching of the server was deactivated. Once it was verified that everything was in order, the web form was restored. All this took place within a period of thirty minutes."

These actions were carried out by the data processor, who managed the incident at a technical level. According to MAD COOL: "As soon as our service provider, ***CONSULTORIA.1., became aware of the incident, the website was closed to take the appropriate measures regarding what had happened, which are also clarified throughout this document. Specifically, the failure was detected at 15:15 (...), access to the users to the relevant form was immediately closed, and by 15:45 the problem was already resolved."

On the same (...) of 2023, the security breach was analyzed and recorded by ***CONSULTORIA.1. as this entity was the subject of it, and this documentation was provided to MAD COOL.

Additionally, an analysis of the security breach and incident record, prepared by the data processor, is provided. The description of the incident recorded is: "During the launch of a data confirmation form for the Mad Cool 2023 festival, some users were able to see data from other users that did not belong to them. It affected (...) users."

2.3. Regarding the causes that made the breach possible

As noted, according to the statements from MAD COOL, the origin of the breach was caused by an incorrect configuration of the server hosting the platform, resulting from human error during the review of a web form deployment.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/23

This deployment was executed due to a migration of the technological environment carried out on the same day as the incident. The report prepared by the person in charge reflects this fact and the motivation for this action: "It was decided to carry out a migration that same morning because a large volume of users was expected to access the form, and the system was moved to a more powerful server. This server had a micro-cache enabled, and until it was disabled, the problem was not resolved."

The enabling of that micro-cache resulted in the fact that, for a period of time, 2 seconds according to MAD COOL, when a user accessed the form, their data could be viewed by other users who were also on the platform at that moment. As the claimants state, this behavior would be consistent with the description of the events provided, in which it was possible to view the data of different users by reloading the webpage.

A technical report from the data processor is provided with the technical details of the incident and the functioning of the micro-cache. It should be noted that the technological environment was deployed on the infrastructure of a third party as a sub-processor, the entity ***COMPANY.1. The data processor states in this regard: "The software is hosted on the servers of ***COMPANY.1. This company offers a micro-cache service by default to speed up the loading of web pages."

The security measures that were available, aimed at attacks by malicious third parties (...), are not applicable in this type of internal case.

2.4. Impact of the breach.

According to MAD COOL, the total number of potential affected users was (...) users, who had access to the web form until the detection of the incident and the closure of the platform. As indicated in the report prepared by the person in charge: "This does not mean that the data was visible to all users who accessed the platform nor that all users could access all the data."

Based on this, the exact magnitude of the impact cannot be determined, as it is not possible to know with certainty which users saw which data. According to MAD COOL: "((...)) there are both possible victims and individuals whose data was definitely compromised. Therefore, from the figure of (...) individuals, we conclude that we do not have one hundred percent certainty that all have ultimately been affected subjects, including in the breakdown provided in the attached file, both the potential affected and those definitely affected."

A list of affected users is provided, with the data that was involved in the breach. MAD COOL provides a list of users definitely affected and another of possible affected users. Out of a total of (...) users, (...) are listed as "possible victims," while (...) would have had their data compromised with certainty. The date and time of access are also noted, grouped within a 32-minute interval between 14:43 and 15:15, with the exception of one user who accessed at 14:16.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/23

Regarding the issue of the user who accessed outside the time window of the breach, MAD COOL states the following: "At 14:43 hours, a mass mailing was sent to the attendees to access the platform, and (...) people entered until 15:15 hours when we closed the platform.

That user who accessed earlier did so sporadically, because the platform was published but not announced, allowing them to enter at 14:16 hours. We have included that user in the list because they accessed during the day, but they were not affected because the problem only impacted those who entered within 2 seconds after the previous user, which occurred when the mass mailing was sent at 14:43 hours."

The total number of users registered on the platform was 29,140 people.

The data affected by the breach were as follows:

- Name and surname.
- Postal address.
- Phone number.
- Email address.

Finally, regarding the possible compromise of integrity, MAD COOL states: "The data that users modified during the time the incident lasted were discarded, and when the problem was resolved, the original data was re-imported, so no data changes from that period have been taken into account."

2.5. Communications maintained for the resolution of the breach.

A copy of the communication sent by the data processor to the data controller is provided. This document is signed as of April 13, 2023, and it recounts the events without going into great detail about the origin of the incident: "The security breach suffered has caused unauthorized access to personal data, specifically, to identifying data of the affected individuals by other clients." In any case, it does include the number of affected individuals, the types of data involved, and the time window of the incident.

Along with that communication, a copy of the incident analysis, previously mentioned, is provided. Additionally, communications between the data processor and the sub-processor (**COMPANY.1) are provided. There are no communications on the date of the events, as they state that they are deleted after one year. The communications provided are between October 3 and 6, 2023, following the request made by this Agency, as they state. In these communications, the representative of the data processor requests accreditation of the functioning of the micro-cache, and according to the conversations held, the sub-processor confirms the functioning previously detailed for an interval of 2 seconds.

2.6.- Possible consequences for the affected individuals and assessment of the incident by the data controller.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/23

MAD COOL states the following in this regard: "Given the type of data affected by the security incident, it is understood that the rights and freedoms of users have NOT been harmed at any time. No damage has occurred to data included within the special category of personal data or particularly sensitive data. It is important to highlight at this point that no personal data that usually concerns clients, such as payment data, for example, bank card numbers, has been exposed."

On the other hand, the data processor, in the analysis of the incident, concludes: "The observation of this set leads us to estimate that we are facing a security breach, specifically regarding the confidentiality of personal data. Consequently, and after the analysis carried out, we can observe how its quantitative and qualitative values do not pose a risk to the rights and freedoms of natural persons. In short, it is not considered to be a high risk, according to the criteria given by Regulation (EU) 2016/679; therefore, there is no need to notify the incident to the competent supervisory authority or to the affected parties."

Consequently, as mentioned in the first point of this report, MAD COOL did not notify this Agency.

3. Communication to the affected parties.

MAD COOL publicly released an informative statement regarding the incident on April 13, 2023. This statement "was visible on the website for several weeks," as stated.

A copy of the published statement is provided. It informs about the incident, although it does not delve into its origin or the type of data affected, nor does it specify the measures adopted. A fragment of it is reproduced below: "In relation to the latest news regarding the incident of viewing entries on the MAD COOL AREA website, in which your personal data may have been affected, we want to indicate that, from the moment we became aware of this incident, we have been the main interested parties in clarifying the facts.

In this regard, we have conducted a quantitative and qualitative analysis of the risks, taking into account the volume and possible impact of this incident on the rights and freedoms of the affected parties. As a result of this analysis, we have been able to verify that the security incident did not pose a high risk to the rights and freedoms of natural persons."

An email address is provided for resolving any doubts regarding this matter: "From our entity, we want

to be transparent about the inconveniences caused and we are at the disposal of any interested party to assist with any questions that may arise, as well as to inform you regarding the protection of your personal data. Therefore, we ask that any questions you may have or comments you wish to convey to us be sent to the email address pulseras@madcool.es, from which we will provide a personalized response.”

4. Regarding the security measures implemented

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/23

4.1. Security measures implemented prior to the breach in the data processing where it occurred. MAD COOL has provided a copy of the audit carried out as of March 1, 2022, on the data processor. The scope includes the automated and manual processing of personal data for which the audited person or entity is responsible. The audited processing activities are:

- Attention to the rights of individuals
- Clients
- Notification and communication of personal data security breaches to the supervisory authority and to the affected parties
- Occupational Risk Prevention
- Suppliers
- Advertising and commercial prospecting
- Human Resources
- Daily work record
- Website users

The assessment is favorable, stating in the report: “In the audited person or entity, the appropriate technical and organizational measures are generally met to ensure a level of data security adequate to the risk, although there are still some caveats that advise the adoption of necessary corrective or complementary measures.”

The existence of the following measure is verified: “Own web server. The existence of a web server owned by the entity responsible for the processing is examined.”

The effective application of this measure, a priori, would not have required the provision of services by the sub-processor.

Additionally, a copy of the periodic control document dated May 3, 2023, also conducted by ***CONSULTORA.2., is provided, which has a favorable assessment.

A document titled “Management of data security breaches” is also provided.

Information has been requested from the data processor regarding the procedure in place at the time of the events for carrying out deployments/migrations, as well as the available testing battery.

The processor has provided information on the procedures for testing forms and deployment on servers, as well as the testing battery carried out. Among these procedures, the following checks are included:

- (...)
- (...)
- (...)
- (...)

Additionally, accreditation of the tests carried out for the deployment in question that caused the breach is provided, using the tool ***HERRAMIENTA.1. According to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/23

The data controller states: “Regarding the tests carried out for the deployment that caused the incident, we have documented all the evidence. The tests conducted include:

- (...)
- (...)
- (...)
- (...)

Once the code is validated, deployment would proceed. In particular, as mentioned in the internal protocols provided by the data controller, the verification of the server environment is contemplated within the operational framework of their development department. On that point, the following is indicated in said documentation: “(...).

(...).”

No mention has been found regarding the review of the micro-cache or verification of similar parameters.

Finally, the data controller has provided information regarding the security measures of the technological environment. (...).

4.2. Reason why the implemented security measures did not prevent the incident.

As noted, the security measures were focused on preventing attacks by malicious third parties, as well as possible intrusions into the system. No specific mechanisms aimed at reviewing the server parameters or, in particular, verifying the micro-cache have been accredited.

4.3. Technical and organizational measures adopted to avoid, as much as possible, incidents like the one that occurred.

MAD COOL states the adoption of the following measures and proposals focused in this direction:

- Review of the data protection system: a data security document is provided, prepared by the entity ***CONSULTORA.2., whose scope is focused on the proactive responsibility of the data controller (“this document is prepared to comply with the provisions of Article 32 of the aforementioned Regulation (EU) 2016/679”, “MAD COOL FESTIVAL SL, which, as the data controller, commits to adopting the appropriate technical and organizational measures to ensure a level of security appropriate to the risk”).
- Hiring trusted providers: MAD COOL states that it resorts to “reliable providers or data processors that offer us sufficient guarantees of compliance with the necessary technical and organizational measures when providing their service.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/23

As they indicate, they believe that their current provider offers such guarantees. As evidence of this, they provide accreditation of the communication that was made to them by the processor alerting them of the facts, which has been previously addressed in point 2.5.

On the other hand, the data controller indicates that a notification software has been implemented that, through a query to a timestamp, analyzes whether the server has an active micro-cache, sending an alert to the technical team and blocking the execution of the program.

Regarding the development environment, the data controller states that additional measures have been adopted such as (...) and reinforcement actions in the production deployment of new versions, such as agile methodologies and code review.

5. Regulatory compliance.

5.1. Regarding the data processing agreement

MAD COOL has provided copies of the data processing agreements, both as of the date of the incident (signed on January 23, 2023) and the one currently in force (signed on April 17, 2023). The reason for signing a new contract, according to MAD COOL, would be: “this contract was reviewed and subsequently modified concerning the operations to be carried out on personal data, which is included in the annex of the contract. Such reviews will be conducted periodically or when an incident of this

type occurs to ensure that the contract is always perfectly updated.”

In both contracts, the entity ***CONSULTORA.1 is listed as the processor and MAD COOL FESTIVAL S.L. as the data controller. In both contracts, it is verified that the following aspects are included, among others:

- The object of the contract: provision of IT services for events, with the activity of the controller being “event organizer” and that of the processor “IT services for events.”
 - Obligations of the processor: “Process the data in accordance with the instructions of the data controller. If the processor believes that any of the instructions infringes Regulation (EU) 2016/679 or any other provision regarding data protection of the Union or the Member States, the processor shall immediately inform the controller.”
 - “Maintain, in writing, a record that contains (...) technical and organizational security measures.”
- “Implement the security measures set out in the ANNEX of this contract. In any case, the DATA PROCESSOR must implement mechanisms to:
- a) Ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services.”
 - In the event of a security breach: “The DATA PROCESSOR shall notify the DATA CONTROLLER without undue delay, and in any case before the maximum period of 24 hours (...) of any data security breaches.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/23

personal under their charge of which they have knowledge, together with all relevant information for the documentation and communication of the incident.”

- Regarding subcontracting: “THE DATA PROCESSOR may not subcontract any of the services that are part of the object of this contract that involve the processing of personal data, except for auxiliary services necessary for the normal functioning of the services of the processor.”

As differences, it is noted as stated by MAD COOL that in the contract signed subsequently, more operations to be performed with personal data are included: “organization, structuring, adaptation or modification, extraction, comparison or verification, combination or interconnection, and destruction,” in addition to those already reflected in the initial contract.

Additionally, the new contract also indicates the need for the destruction of data once the service is completed.

In relation to the sub-processing of data with the provider ***COMPANY.1, MAD COOL has stated the following: “As it is a provider of (...), they inform us that the service of ***COMPANY.1 is contracted directly online, accepting the legal terms of ***COMPANY.1 at the time of contracting.”

Additionally, they indicate that there are no communications maintained with ***CONSULTANT.1 regarding the subcontracting of IT services.

A copy of the clauses is provided, available on the website of this provider (...).

Among the different points, there is one dedicated to the data processing assignment, which states the following: “The client is in any case the Data Controller of the data hosted in their hosting services. By default, the hosting services of ***COMPANY.1 incorporate a micro-cache system. If the client needs this micro-cache to be deactivated from their service to comply with any aspect of data protection regulations, they must explicitly request this deactivation from our technical team through our ticketing system.”

According to that clause, the origin of the micro-cache being enabled would be recorded there, and the responsible party or the data processor must be the entities that should have requested its deactivation prior to the production deployment of the form.

5.2. Regulations regarding the affected processing.

MAD COOL has provided the following documentation:

- Record of Processing Activities, dated May 5, 2023. According to MAD COOL, the affected processing would be included under the designation “clients,” in Processing Activity number 2 of the

provided document. It is considered a processing with a standard risk, without specific risks. In this processing, the entity ***CONSULTANT.1 is listed as the data processor, in the capacity of providing IT services for events. No reference has been found to the entity ***COMPANY.1.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/23

- Risk Analysis: documentation evidencing the risk analysis conducted on February 1, 2023, has been provided. This analysis was prepared by ***CONSULTANT.2. Among the analyzed threats, none similar to the occurred event has been observed, although “Contracting with a data processor that does not provide sufficient guarantees to apply appropriate technical and organizational measures” and “Human errors” are contemplated.

The assessment of the analysis results in an acceptable residual risk, noting among other aspects that “this risk analysis in the processing of personal data is merely a theoretical exercise that requires its full implementation to guarantee the rights and freedoms of the data subjects. It is essential that adequate supervision and a subsequent review of the implementation of the control measures proposed in the risk analysis are carried out to reduce the inherent risk to a residual risk that allows the processing to be carried out while guaranteeing the rights and freedoms of natural persons.”

6.- Other aspects.

6.1. Assessment of the breach using the Comunica-Brecha tool from the Spanish Data Protection Agency.

A simulation has been carried out, based on the data collected regarding this breach, regarding the need to communicate the breach. The obtained assessment has been:

“IT WOULD NOT BE NECESSARY TO COMMUNICATE THE SECURITY BREACH TO THE AFFECTED PARTIES in accordance with Article 34 of the GDPR as no high or very high risk to the rights and freedoms of the affected subjects is perceived. However, it could be considered to do so voluntarily, as an exercise in transparency and proactive responsibility.”

In any case, as noted regarding this tool, it is an aid for decision-making, but the final decision belongs inevitably to the data controller, and in no case does its use represent the pronouncement of this Agency on the application of Article 34 of the GDPR for a specific personal data breach.

6.2. Regarding the training of employees of the data processor.

The data processor has stated in the data processing assignment contract dated (...) of 2023 that a series of good practices and internal protocols are followed to ensure the security of information and protection of personal data. Among them would be (...).

Additionally, it states that during the onboarding process, specific procedures related to information security and cybersecurity are imported. A copy of the internal codes from the development department is provided.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

12/23

FIFTH: On January 7, 2025, the Presidency of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party, for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5.a) and 83.4 a), respectively, of the GDPR.

SIXTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and after the period granted for the submission of allegations had elapsed, it was confirmed that no allegations had been received from the accused party. Article 64.2.f) of the LPACAP - a provision of which the accused party was informed in the opening agreement of the

procedure - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the accused party, and the sanction that could be imposed. Therefore, considering that the accused party has not submitted allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

SEVENTH: After the initiation agreement was notified and before this Authority issued a resolution, on January 20, 2025, a document from MAD COOL was received, providing proof of payment with a discount for early payment (20%). On February 17, 2025, a new document from MAD COOL was received, confirming the waiver of any action or appeal in the administrative pathway, in accordance with the provisions of Article 85.3 of the LPACAP.

EIGHTH: According to the report obtained from the AXESOR tool, the entity MAD COOL is a company established in 2015, with a business volume of (...) euros in 2021.

In view of all the actions taken by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: On April 11, 2023, MAD COOL launched a confirmation form for the personal data of users who had purchased tickets for the festival taking place in July of that year.

SECOND: During the morning of the launch of the web form, a migration of the platform to a new server was carried out, and during this migration, an existing micro-cache on that server was not deactivated. This two-second micro-cache caused that from the moment a user accessed the form, for a maximum of 2 seconds, the subsequent users who accessed it could see their data. Once those 2 seconds elapsed, the user's data would stop being displayed.

THIRD: The incident lasted between 14:45 and 15:15 and affected (...) users. Among them, there was a certain loss of confidentiality of personal data for 406 individuals. The data affected by the breach included: first and last name; postal address, phone number, and email address. The personal data breach was communicated by MAD COOL through a statement published on its website on April 13, 2023.

FOURTH: The migration was carried out by the data processor of MAD COOL - ***CONSULTORIA.1-, who managed the incident at a technical level. However, the technological environment was deployed on the infrastructure of a third party as a sub-processor, the entity ***COMPAÑIA.1. This company offers a micro-cache service by default to speed up the loading of web pages. In the internal protocols of the data processor, related to the verification of the server environment, there is no mention of reviewing the micro-cache or verifying similar parameters.

FIFTH: The service of ***COMPAÑIA.1 is contracted directly online, accepting the legal terms of the website at the time of contracting. Among these terms, the one dedicated to the data processing agreement states the following:

The client is in all cases the Data Controller of the data hosted on its hosting services. By default, the hosting services of ***COMPAÑIA.1 include a micro-cache system. If the client needs this micro-cache to be deactivated from their service to comply with any aspect of data protection regulations, they must explicitly request this deactivation from our technical team through our ticketing system."

According to this clause, the micro-cache is enabled by default, unless the data controller or the data processor had requested its deactivation prior to the production deployment of the form.

SIXTH: The security measures that were available at the time of the breach (...) were focused on malicious attacks by third parties. Measures such as the implementation of a VPN were adopted after the personal data breach.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles

47, 48.1, 64.2, and 68.1 of the
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/23

Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), establishes that the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, to the extent that they do not contradict them, by the general rules on administrative procedures in a subsidiary manner."

II

Preliminary Issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, given that MAD COOL carries out, among other processes: the collection and storage of personal data of individuals: name, surname, email, phone number, postal address, postal code, city, and country.

MAD COOL carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

III

Unfulfilled Obligation. Integrity and Confidentiality

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

The aforementioned principle of confidentiality obliges data controllers to ensure that personal data is processed securely, preventing unauthorized access, misuse, or disclosure to unauthorized third parties. This includes implementing appropriate technical and organizational measures to protect the data against potential personal data breaches, both external and internal.

These measures must be appropriate to the risks that may arise from the processing and must be reviewed and updated periodically to ensure their effectiveness.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

15/23

In this case, the principle of confidentiality would have been violated due to a technical failure in the configuration of the server hosting the personal data confirmation form. During the migration to a new server, the active micro-cache in the system would have allowed the personal data of a user accessing the form to be visible for a few seconds to other users entering during that interval. This technical failure would have exposed personal data in an unauthorized manner, compromising its confidentiality. Regardless of the duration of the personal data breach, the exposure would constitute unauthorized processing, as the personal data of users was accessible to third parties without their consent.

The accused party, as the data controller, has the obligation to ensure the security of personal data throughout the entire processing process. In this case, the investigative actions indicate that sufficient controls were not implemented to ensure that the server was correctly configured before the launch of

the form. The decision to carry out a migration at a critical moment, on the same day as the launch, without conducting adequate tests to identify potential technical failures, demonstrates serious negligence on the part of the data controller that directly enabled the personal data breach.

The mentioned incident evidences a presumed violation of the confidentiality principle established in Article 5.1 f) of the GDPR. Although the accused party took measures to close the form and minimize the impact, in order to contain the damages, the error in the server configuration and the lack of adequate preventive measures allowed for the unauthorized exposure of personal data, which indicates a deficiency in the technical and organizational measures implemented.

Therefore, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to MAD COOL for violation of the previously transcribed article.

IV

Classification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following article, which shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent pursuant to Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/23

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the statute of limitations, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will be subject to a three-year statute of limitations, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

V

Proposal for Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 "Sanctions and Corrective Measures" of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In this case, considering the seriousness of the possible infringement, particularly the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the business volume of MAD COOL, amounting to 357,000 euros in the year 2021, is considered beforehand.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 5.1.f) of the GDPR, allows for the setting of an administrative fine of 2,000.00 euros.

VI

Unfulfilled Obligation. Security of Processing

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/23

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical

and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
 - b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
 - c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
 - d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.
2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.
3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.
4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

The aforementioned Article 32 of the GDPR aims to ensure a level of security appropriate to the risk, in relation to the processing of personal data, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity to the rights and freedoms of natural persons. Thus, the controller and the processor shall implement appropriate technical and organizational security measures to ensure such a level of security appropriate to the risk. It is worth noting that for this article to be considered breached, it is not necessary for there to have been improper processing or a personal data breach; rather, the mere failure to adopt or implement appropriate technical and organizational measures constitutes a violation of the aforementioned article.

In the present case, despite the existing security measures prior to the personal data breach, such as the implementation of HTTPS and CSRF protection, the absence of a security measure that was subsequently adopted reactively after the occurrence of the personal data breach is noteworthy.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/23

Independent security from the personal data breach: the implementation of VPN to secure communications between authorized users and servers. Thus, during the course of the investigative proceedings, the defendant stated the following:

"Regarding the development environment, the data controller states that additional measures have been adopted such as (...) and reinforcement actions in the production deployment of new versions, such as agile methodologies and code review."

From this statement, it follows that the entity adopted the implementation of a VPN reactively, after the personal data breach, which shows that this measure was not in place beforehand. The nature of the activity carried out, which includes remote access and the management of sensitive personal data in a server environment, makes the adoption of a VPN an essential measure to ensure the security of communications and prevent unauthorized access.

The implementation of a VPN in this context allows for an additional layer of protection, ensuring that connections between users and servers are made in an encrypted and secure manner. This is particularly relevant in activities where access to the technological environment poses an inherent risk of exposure or intrusion if measures like this are not adopted. By not having a VPN prior to the incident, a level of security proportional to the risk would not have been guaranteed, which would

constitute a breach of Article 32 of the GDPR.

As previously indicated, Article 32 requires the adoption of appropriate technical and organizational security measures to ensure a level of security adequate to the risk to the rights and freedoms of natural persons arising from the processing of personal data. The absence of this basic security measure, as the VPN is widely recognized as a standard practice for protecting data in similar technological environments, would highlight a defect in the identification, assessment, and management of risks by the entity. The lack of this security measure is independent of the personal data breach, as its absence neither enabled nor had a direct impact on the personal data breach. Consequently, the omission of its implementation would constitute a violation of the aforementioned Article 32 of the GDPR, regardless of whether the personal data breach occurred or not, for failing to adopt appropriate security measures to ensure a level of security adequate to the risk; in this case, the non-implementation of a VPN.

Therefore, in accordance with the evidence available at this time of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to MAD COOL, for violation of the previously transcribed article.

VII

Classification of the infringement of Article 32 of the GDPR and qualification for the purposes of prescription

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/23

Article 83.5 of the GDPR classifies the violation of the following article as an administrative infringement, which shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total global annual turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent pursuant to Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the sole purpose of the statute of limitations, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and shall be subject to a three-year statute of limitations, particularly the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

VIII

Proposal for Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are effective, proportionate, and dissuasive in each individual case.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage suffered;

- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and Corrective Measures” of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the behavior of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In the present case, considering the severity of the possible infringement, particularly the consequences that its commission causes to the affected parties, the imposition of a fine, in addition to the adoption of measures, if appropriate, would be warranted.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To ensure these principles, the turnover of MAD COOL of (...) euros in the year 2021 is considered as a preliminary factor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/23

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of an administrative fine of 1,500.00 euros.

IX

Taking the above into account, it should be noted that, in accordance with the provisions of the LPACAP and the jurisprudence of the Supreme Court in this matter, voluntary payment by the alleged responsible party does not exempt the Administration from the obligation to resolve and notify all procedures, regardless of their initiation form.

Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide on all issues raised by the interested parties and any others arising from it.

Therefore, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the following infringements and TO CONFIRM for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanctions indicated in the initiation agreement of the present sanctioning procedure for the commission of the aforementioned infringements:

- For the infringement of Article 5.1 f) of the GDPR: 2,000.00 euros

- For the infringement of Article 32 of the GDPR: 1,500.00 euros

The sum of the aforementioned amounts totals 3,500.00 euros.

After the claimed party proceeded with the prompt payment, although without acknowledgment of responsibility, a reduction of 20% of the total mentioned is applied, which results in a final amount of 2,800.00 euros.

SECOND: TO DECLARE the termination of the procedure due to the prompt payment made by MAD COOL, with NIF B87381042, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or renunciation of any action or administrative appeal, this authority accepts the express renunciation stated by the claimed party, consequently precluding the filing of an optional appeal for reconsideration against this resolution, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since there is no administrative appeal available due to the express renunciation, this resolution will be fully enforceable from the notification thereof.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative process may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

938-100325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es